Local LLM Security Assessment Lab

Technical Assessment and Evidence Review

OWASP Juice Shop · Unsloth Studio · Kali Linux

Repository
osama-git05/juice-mcp-lab

Source reviewed
b892b45beb5e54215cec0eac2a2729e2a1552504

Review date
7 November 2026

This report describes implemented behaviour and committed evidence. It records local model guidance and endpoint observations. Vulnerability validation and MCP execution remain to be demonstrated.

1 Executive assessment

The repository demonstrates a local Qwen model producing a reconnaissance checklist and a fixed Python workflow probing ten Juice Shop URLs. The existing evidence supports target availability and successful local inference.

The source uses direct HTTP requests. It contains no MCP client or server, FastAPI application, retrieval pipeline or adaptive execution loop. The original report marked all ten cases vulnerable without preserving evidence sufficient to support those conclusions.

Outcome	Evidence review
Target availability	Demonstrated by the application and runner captures
Local model guidance	Demonstrated by the printed checklist
HTTP probes	Ten displayed status observations
Confirmed vulnerabilities	Zero established by the committed evidence
Cases requiring validation	Ten intended vulnerability classes
Remediation	No before-and-after evidence committed

Scope and provenance

The runner and probe captures identify 10.0.2.15:3000. Browser evidence shows 127.0.0.1:3000. The local model API is printed as 127.0.0.1:8888/v1. These are roles and addresses shown in the submitted material, not fresh measurements from this review.

The image reference file pins the Juice Shop container digest. Reliable run timestamps, full requests, response bodies, response headers and per-test identity controls are not committed.

No live scanning or model calls were performed in this review. All status observations below are transcribed from the committed screenshot. They are historical observations and not a new run.

2 Implemented architecture

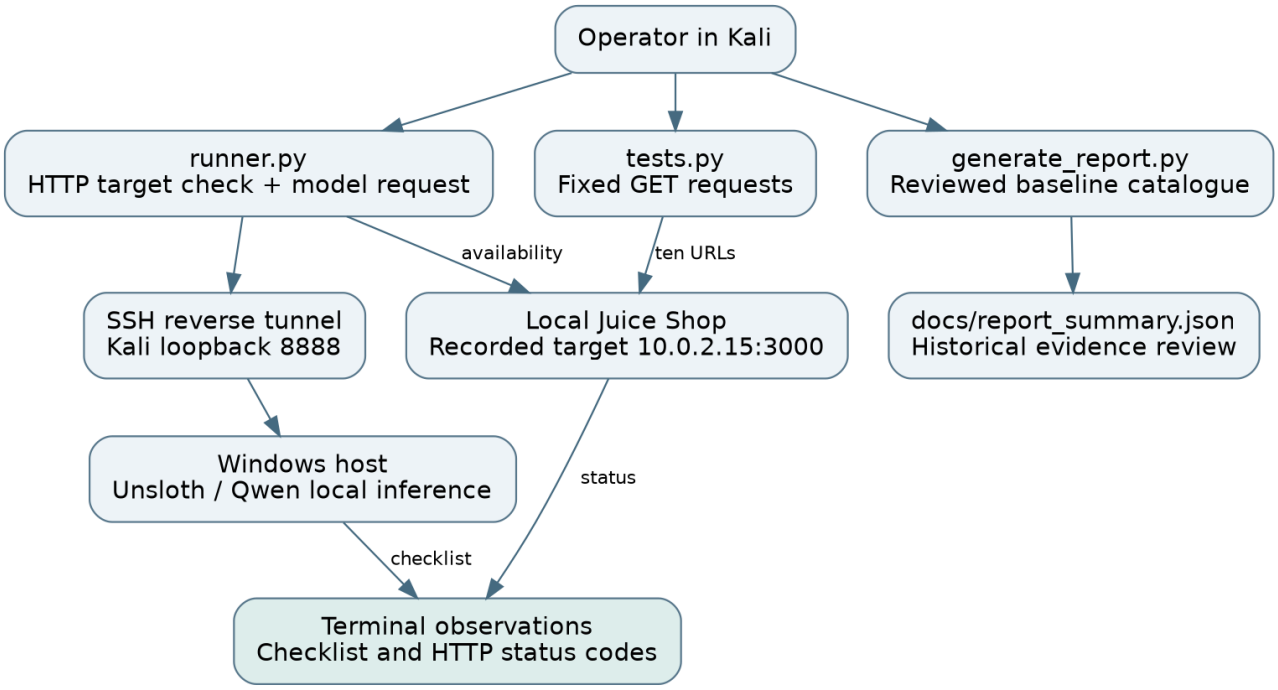


Figure 1. Current source behaviour. The report exporter is independent of live endpoint execution.

runner.py checks the target, then sends a checklist prompt to Unsloth through an OpenAI-compatible API. tests.py sends GET requests to ten catalogue URLs in a fixed loop. Its model-evaluation helper is defined but unused.

The original exporter constructs a completion summary from hardcoded case labels. The revised exporter explicitly identifies its historical baseline and marks all vulnerability conclusions unverified.

Tunnel interpretation

In a VirtualBox NAT configuration, host port 2222 can forward to Kali SSH port 22. The reverse SSH connection forwards Kali loopback 8888 to the host model listener. A separate host-only variant is also documented. The safe screenshots do not establish the exact original SSH command or adapter configuration.

3 Model and application evidence

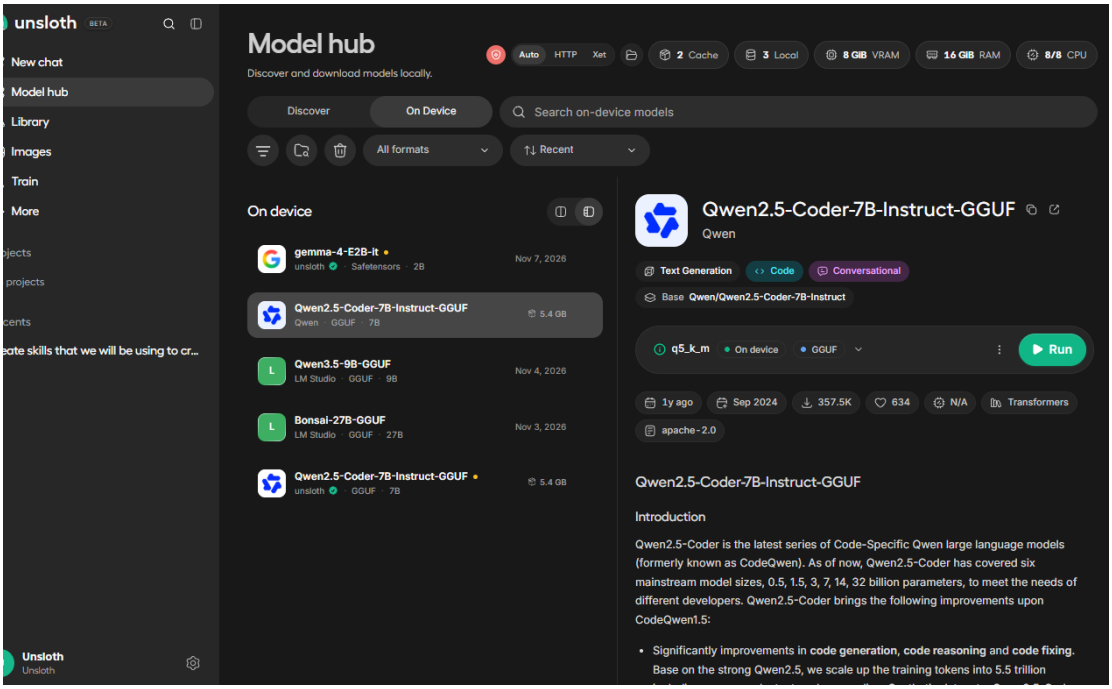


Figure 2. The Unsloth model-selection screen shows Qwen2.5-Coder-7B-Instruct GGUF. The selection alone does not measure inference quality or resource use.

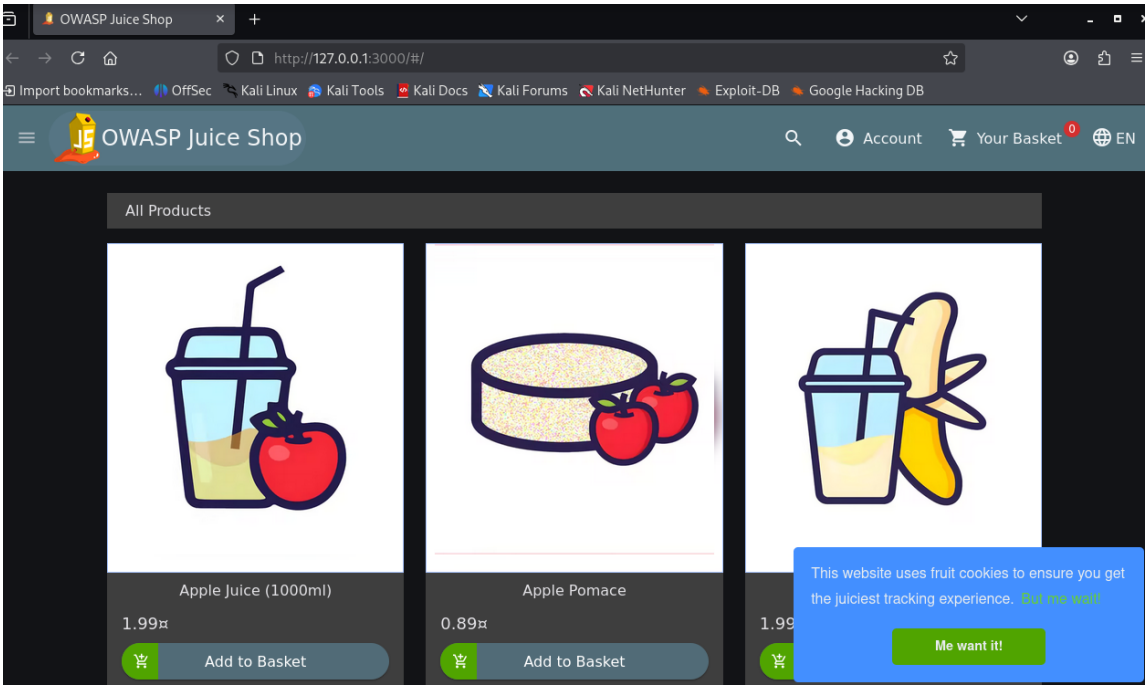


Figure 3. The Juice Shop page is reachable in a local browser. This is application availability evidence.

4 Execution evidence

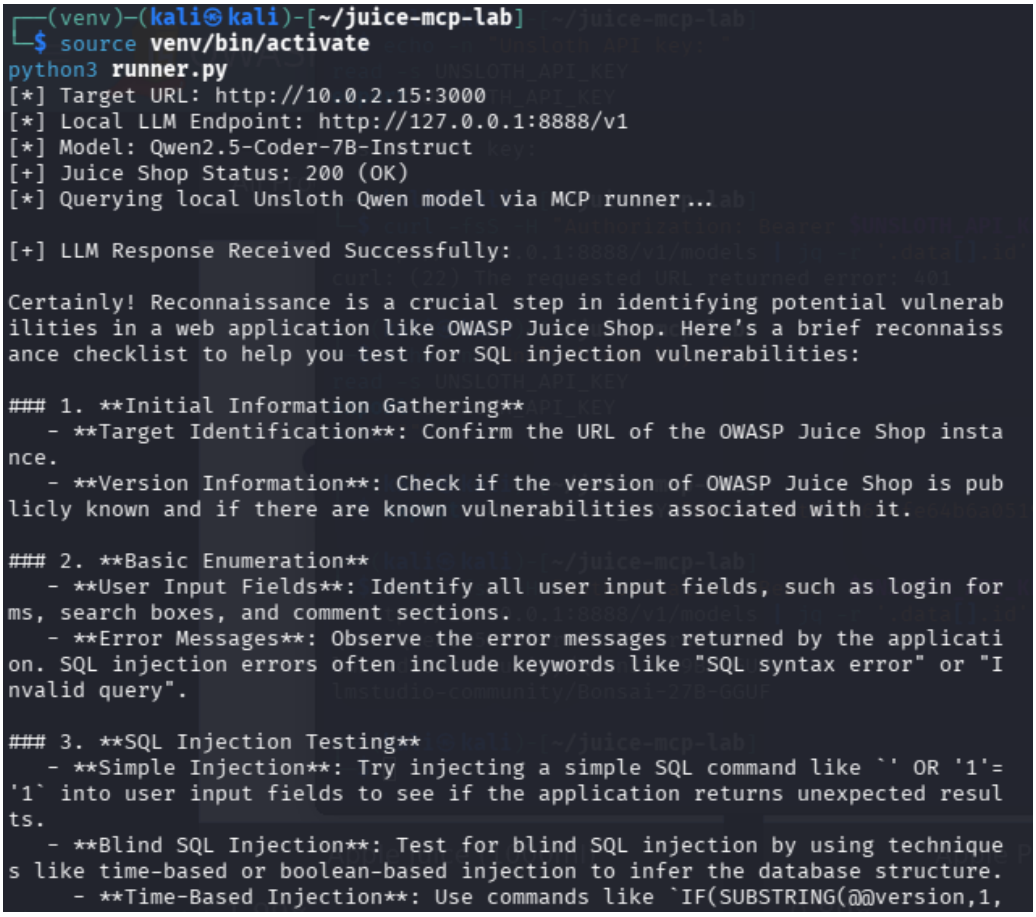


Figure 4. The Python runner prints target HTTP 200 and receives a local-model checklist. Its MCP wording is a console label; the source uses direct REST calls.

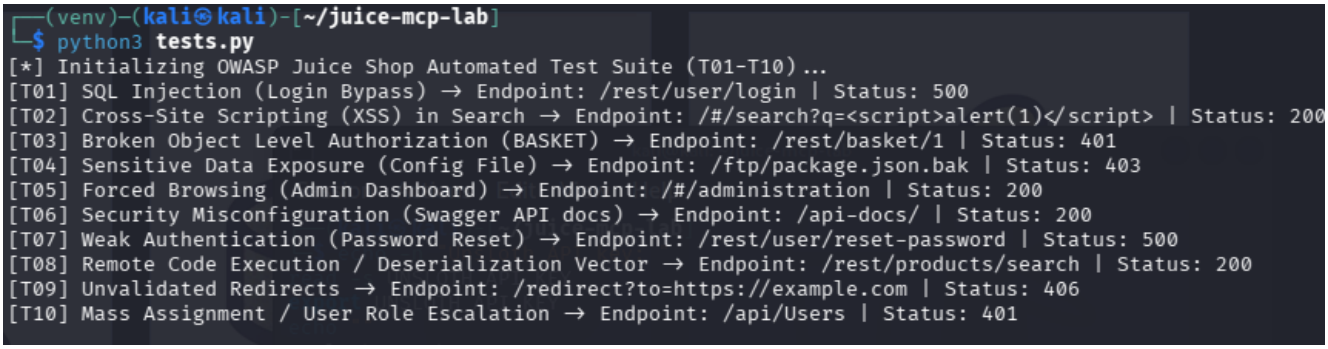


Figure 5. Ten GET probe statuses. No response bodies, browser execution contexts or authenticated comparisons accompany this capture.

5 Review of the ten cases

ID	Captured observation	Assessment
T01	Login GET returned 500	No authentication bypass demonstrated
T02	Hash-route request returned 200	Fragment not sent; browser XSS untested
T03	Basket GET returned 401	Denied for the tested context; IDOR unverified
T04	Backup candidate returned 403	Request denied; no file content demonstrated
T05	Admin hash route returned 200	No admin function access demonstrated
T06	API-docs route returned 200	Body unavailable; exposure significance unknown
T07	Reset GET returned 500	Intended reset workflow untested
T08	Search GET returned 200	No validated input or RCE evidence
T09	Redirect request returned 406	Request rejected in the displayed run
T10	User endpoint GET returned 401	No write or role mutation attempted

All ten vulnerability cases remain unverified. Negative responses are valid observations for those exact probes; they do not establish that all related attack paths are secure.

Required confirmation

Preserve correct methods, baseline responses, exact inputs and meaningful returned content. Browser issues require browser execution evidence. Access control requires two controlled identities and resource ownership checks. Any approved state-changing test must independently verify the changed state.

6 Assessment process findings

Unsupported conclusions

The earlier report declared every case vulnerable. Replace categorical claims with observations and promote findings only when their confirmation threshold is met.

Method and route mismatch

Hash fragments are client-side routing data. GET requests to login, reset and user endpoints do not exercise the intended workflows. Correct test design is necessary before assigning a finding.

Planning is disconnected from execution

The model checklist is printed. There is no code path that turns its selected action into a bounded MCP tool call. Demonstrate a genuine protocol exchange and action trace before describing autonomous testing.

Credential exposure

The reviewed tree contained an API key in .env and a screenshot. Both are removed in the revised tree. Revoke the old credential, store its replacement privately and use the owner-led sensitive-data removal process for history.

Evidence limitations

The committed observations do not include stable run records, stream hashes, duration measurements or independently validated security outcomes. Local API configuration supports a local inference design, but there is no network trace demonstrating zero external traffic.

7 Next milestone and handover

1. Expose one fixed local check through MCP and record initialise, tools/list and tools/call.

2. Enforce the asset and permitted arguments in the execution layer, then test an out-of-scope rejection.

3. Preserve a timestamped request and full result before asking the model to draft a report entry.

4. Connect one model-selected follow-up to the tool and preserve the preceding observation and decision.

5. Validate one existing case using the confirmation threshold in docs/TEST_MATRIX.md, then extend only after the evidence path works.

Repository handover

The revised documentation includes a README, setup guide, implemented and planned architecture diagrams, test matrix, evidence index, assessment report, credential handling guidance and an honest JSON exporter. Existing safe screenshots are captioned for their demonstrated scope.

Documentation verification

The package is checked for local link targets, diagram generation, Python source syntax, expected JSON output and absence of the removed environment file and exposed screenshot. No live target assessment is asserted.

References

Repository

OWASP Juice Shop

OWASP Web Security Testing Guide

Unsloth API setup

GitHub sensitive data removal